SECCIÓN 6.1

Rol del SOC en la respuesta inicial a incidentes

Temas de esta sección:

- Qué significa respuesta inicial y cómo difiere del análisis de alertas
- Qué puede y qué NO debe hacer el SOC sin autorización
- El riesgo de actuar demasiado rápido vs demasiado tarde
- 5 objetivos clave: entender, preservar, escalar, evitar daño, comunicar
- El SOC en un ecosistema de equipos: IR, IT, identidad, negocio
- Ejercicios: clasificar acciones y analizar tres casos reales

Una alerta lleva al análisis. La evidencia suficiente lleva a la respuesta. Son dos momentos distintos con lógicas distintas.

ANÁLISIS — ¿Qué está pasando?	RESPUESTA INICIAL — ¿Qué hacemos ahora?
▸ Revisar parent process y command line	▸ Revisar alcance y evidencia posterior
▸ Buscar actividad previa y posterior	▸ Preservar eventos y detalles de alerta
▸ Consultar reputación del hash	▸ Identificar archivo origen y persistencia
▸ Buscar el mismo indicador en otros hosts	▸ Escalar con contexto a IR
▸ Documentar línea temporal	▸ Evaluar si corresponde aislar el endpoint
▸ Validar si existe ticket o cambio	▸ Recomendar acciones de contención
▸ Revisar proceso y usuario involucrado	▸ Coordinar con IT o identidad

6.1 | Qué puede y qué NO hace el SOC sin autorización

El SOC detecta, coordina y aporta contexto — pero no siempre ejecuta todas las acciones:

El SOC PUEDE hacer	SIN AUTORIZACIÓN el SOC NO debería
▸ Confirmar la alerta inicial	✘ Aislar un servidor productivo
▸ Revisar eventos relacionados	✘ Reiniciar un equipo crítico
▸ Construir línea temporal básica	✘ Eliminar archivos sin preservar evidencia
▸ Consultar reputación de indicadores	✘ Deshabilitar cuenta ejecutiva
▸ Preservar evidencia relevante	✘ Bloquear IP globalmente sin validar impacto
▸ Abrir o actualizar ticket	✘ Matar procesos en sistemas críticos
▸ Escalar a equipos correspondientes	✘ Borrar tareas programadas
▸ Solicitar validación a IT o negocio	✘ Informar usuarios masivamente sin aprobación
▸ Recomendar acciones de contención	✘ Declarar públicamente un incidente

6.1 | El riesgo del equilibrio: demasiado rápido vs demasiado tarde

Ambos extremos son peligrosos. La respuesta inicial busca velocidad con criterio:

ACTUAR DEMASIADO RÁPIDO

```
Alerta: posible web shell en servidor de pagos.
Acción impulsiva: apagar el servidor inmediatamente.
```

Posibles consecuencias:

- Caída de servicio crítico
- Pérdida de evidencia volátil
- Interrupción de pagos
- Impacto en clientes
- Dificultad para reconstruir actividad

ACTUAR DEMASIADO TARDE

```
Alerta: cuenta privilegiada con login anómalo.
Actividad posterior: nuevo MFA + regla de reenvío +
descarga masiva.
```

Posibles consecuencias:

- El atacante mantiene acceso
- Exfiltración de más información
- Movimiento a otros sistemas
- Se borran rastros
- Se escalan privilegios

No actuar impulsivamente. No quedarse esperando sin motivo. La respuesta inicial busca ese equilibrio.

En una respuesta inicial, el SOC tiene cinco objetivos simultáneos:

1	**ENTENDER EL ESCENARIO**	Antes de actuar, identificar qué ocurrió, quién está involucrado, qué tan crítico es el activo y qué evidencia existe.	*¿Qué disparó la alerta? ¿Activo crítico? ¿Acción permitida o bloqueada?*
2	**PRESERVAR EVIDENCIA**	Guardar alertas, process trees, command lines, hashes, conexiones, reglas, timestamps y acciones tomadas antes de cualquier acción invasiva.	*Lo que no se registra puede perderse al reiniciar, aislar o borrar.*
3	**DEFINIR SI ESCALAR**	Cuando la evidencia muestra riesgo relevante, escalar con contexto suficiente para que quien recibe pueda actuar sin empezar de cero.	*Escalar no confirma incidente. Indica que requiere atención o análisis avanzado.*
4	**EVITAR DAÑO OPERATIVO**	Aislar endpoint de usuario ≠ aislar servidor de pagos. Cada acción defensiva puede tener impacto. Evaluar criticidad antes de actuar.	*Seguridad y operación deben considerarse juntas.*
5	**COMUNICAR CORRECTAMENTE**	Separar hechos observados, hipótesis y recomendaciones. Adaptar el mensaje al destinatario. No exagerar ni minimizar.	*Una mala comunicación genera confusión, demoras y acciones incorrectas.*

El SOC no responde solo. Es el punto de detección y coordinación que activa a los equipos con capacidad para actuar:

INCIDENT RESPONSE (IR)

Análisis forense, contención avanzada, remediación coordinada. El SOC escala y aporta contexto; IR decide y ejecuta en incidentes confirmados.

IT / INFRAESTRUCTURA

Validación de cambios, acceso a sistemas productivos, aislamiento de hardware. El SOC solicita acciones que afectan disponibilidad operativa.

IDENTIDAD / IAM

Revocación de sesiones, bloqueo de cuentas, revisión de OAuth y MFA. Imprescindible cuando el vector es compromiso de cuenta.

REDES

Bloqueo de IP/dominios, revisión de firewall y proxy, análisis de tráfico. El SOC recomienda; redes valida impacto antes de aplicar.

APLICACIONES / DEV

Análisis de web shells, vulnerabilidades explotadas, acceso a logs de app. Clave en incidentes web o de APIs.

NEGOCIO / DUEÑO DEL SISTEMA

Validación de criticidad, autorización de contención, comunicación a clientes. Necesario cuando el activo afecta operaciones o clientes.

6.1 | Ejercicio: tres casos — qué hacés primero

Tres escenarios distintos, tres primeras decisiones distintas:

MALWARE EN FINANZAS

```
Host: FIN-LAP-022  User: finanzas.paz
WINWORD.EXE → powershell.exe -enc
update.exe en C:\Users\Public\ — Allowed
Conexión a billing-check-update.net
```

1. Preservar process tree y command line
2. Obtener hash de update.exe
3. Buscar otros hosts con mismo hash/dominio
4. Revisar correo origen
5. Escalar → recomendar aislamiento

CUENTA COMPROMETIDA

```
User: legal.romero
Impossible travel — MFA Success
Device: Unknown
Mailbox rule externa + 1,200 archivos SharePoint
OAuth app: Read Mail + Read Files
```

1. Preservar login, regla, OAuth y descargas
2. Revisar sesiones activas
3. Escalar a identidad/IR
4. Recomendar revocación de sesiones
5. Validar con usuario por canal aprobado

WEB SHELL EN SERVIDOR DE PAGOS

```
Server: WEB-PAY-01 — Portal de pagos
WAF Command Injection — Response 200
w3wp.exe → cmd.exe → whoami
shell.aspx en /uploads
Conexión externa desde servidor
```

1. Preservar WAF logs, EDR, archivo y requests
2. NO apagar/borrar sin coordinación
3. Escalar urgente: IR, apps, infra, negocio
4. Evaluar regla WAF específica
5. Coordinar contención con impacto de pagos